

Metodbeskrivning för riskbedömning av kund

Version 2.0 - Integrerad med Celestial Risk Engine

24 oktober 2025

Innehåll

Inledning	2
Definition av risknivåer	2
Princip för riskbedömning	2
Metod för allmän riskbedömning	3
Härledning av hotnivåer per verksamhetsområde enligt myndighetskatalog	4
Celestial Risk Engine - Operationell riskbedömning	6
Motivering av sårbarhetsnivåer per tjänst	12
Sammanfattande beslutsmodell	13
Dokumentation och spårbarhet	14
Uppdatering och revidering	15

Inledning

Denna metodbeskrivning fastställer hur vi som redovisningsbyrå genomför riskbedömningen av kunder, både vid antagandet av nya uppdrag och vid den löpande uppdateringen av befintliga kunders riskprofiler. Syftet är att säkerställa en enhetlig och rättssäker tillämpning av penningtvättslagstiftningens krav på kundkännedom och riskklassificering.

Nytt i version 2.0: Denna uppdaterade version integrerar vår klassiska PTL-metodik (Hot $\times$ Sårbarhet) med automatiserad datainsamling via Roaring API samt analys av bokföringsunderlag (SIE-filer) genom vår Celestial Risk Engine. Detta skapar en tvådelad bedömning:

1. **PTL-metodik (juridisk grund):** Hot $\times$ Sårbarhet = KYC-nivå (standard eller skärpt)
2. **Celestial Engine (operationell):** 0–100 poäng för intern prioritering och beslut

För att upprätthålla ett aktuellt och rättssäkert arbetssätt uppdateras detta dokument minst en gång per år, eller vid behov till följd av ändrad lagstiftning, vägledning från tillsynsmyndigheter eller interna riskobservationer. Ansvarig för uppdatering och godkännande är den verksamhetsansvarige. Vid varje ändring uppdateras dokumentets versionsnummer.

Definition av risknivåer

För att kunna uppfylla penningtvättslagens krav på riskbaserade åtgärder (2 kap. 1 § och 3 §) krävs en systematisk och dokumenterad metod för att identifiera och bedöma risker.

Vi inleder därför med en definition av de risknivåer som tillämpas i vår verksamhet. Risknivån utgör en kombination av externa hot (kundrisk) och interna sårbarheter (tjänstens känslighet), vilket ligger till grund för beslut om kontrollåtgärder och kundacceptans.

- **Hot** – den yttre risken: i vilken grad en viss kundtyp eller verksamhet kan utnyttjas för penningtvätt eller finansiering av terrorism. Bedömningen utgår från den nationella riskbedömningen och avser hur attraktiv kunden är för kriminella aktörer.
- **Sårbarhet** – den inre risken: i vilken utsträckning våra egna tjänster kan manipuleras eller missbrukas utan att det upptäcks. Faktorer inkluderar dokumentation, kontrollrutiner, spårbarhet och insyn.

Princip för riskbedömning

Vi tillämpar en enkel och transparent modell där:

$$\text{Risknivå} = \text{Hot (kund)} \times \text{Sårbarhet (tjänst)}$$

Hotnivån hämtas från den *Nationella riskbedömningen av penningtvätt och finansiering av terrorism i Sverige 2020/2021*¹. Sårbarhetsnivån fastställs internt för varje tjänst utifrån dess kontrollbarhet.

Syftet är att styra vilka åtgärder som krävs enligt penningtvättslagen, med riskpoängen som beslutsunderlag.

Metod för allmän riskbedömning

Vår metod för allmän riskbedömning baseras på den riskmatris och skala som presenteras i *Nationell riskbedömning av penningtvätt och finansiering av terrorism 2020/2021*, utgiven av bland andra Finansdepartementet, Polismyndigheten, Ekobrottsmyndigheten och Finansinspektionen.

Risknivån beräknas genom att multiplicera en bedömd hotnivå med en bedömd sårbarhetsnivå enligt följande formel:

$$\text{Risknivå}_{\text{PTL}} = \text{Hotnivå} \times \text{Sårbarhetsnivå}$$

Varje komponent bedöms på en fyrgradig skala:

- 1 = Låg
- 2 = Medel
- 3 = Betydande
- 4 = Hög

Skalan följer den semikvantitativa metodik som används i den nationella riskbedömningen (bilaga Process och metod", s. 123 ff.). Genom att använda denna metod säkerställs att vår klassificering är spårbar, jämförbar och förankrad i myndighetsgemensamma riktlinjer.

För varje kombination av kundtyp och tjänst motiverar vi bedömda siffror i separata tabeller i efterföljande avsnitt.

¹<https://www.ekobrottsmyndigheten.se/wp-content/uploads/2021/05/nationell-riskbedomning-av-penningtvatt-och-finansiering-av-terrorism-2020-2021.pdf>

Härledning av hotnivåer per verksamhetsområde enligt myndighetskatalog

Som underlag för vår generella riskbedömning har vi utgått från den myndighetsgemensamma rapporten *Nationell riskbedömning av penningtvätt och finansiering av terrorism i Sverige 2020/2021*, utgiven av Ekobrottsmyndigheten, Polismyndigheten, Finansinspektionen m.fl.

Dokumentet innehåller i kapitel 7 (s. 39–117) en sektorskatalog där samtliga verksamhetsområden som omfattas av penningtvättslagstiftningen bedöms individuellt utifrån risken att utnyttjas för penningtvätt eller finansiering av terrorism. För varje sektor anges en risknivå i termerna *låg*, *medel*, *betydande* eller *hög*, med tillhörande motivering.

Automatisk mappning från SNI-kod till hotnivå

Nytt i v2.0: Vi hämtar företagens branschklassificering automatiskt via Roraring API, som returnerar SNI-kod (5 siffror). Denna kod mappas sedan till myndighetens hotnivå enligt följande tabell:

Verksamhetsområde	SNI-kod	Hotnivå
HÖG RISK (4)		
Bygg och anläggning	41.xxx, 42.xxx, 43.xxx	4
Restaurang och catering	56.xxx	4
Städ och fastighetsservice	81.xxx	4
Landtransport	49.xxx	4
Varuhandel (kontantintensiv)	47.xxx	4
Bolagsbildare och företagsmäklare	70.xxx	4
Spelverksamhet	92.xxx	4
BETYDANDE RISK (3)		
Fastighetsmäklare	68.3xx	3
Bokförings-, revisions- och skatterådgivning	69.2xx	3
Oberoende jurister (ej advokatbyråer)	69.10x (ej 69.10.1)	3
Kontorshotell och postboxföretag	82.11x	3
Finansiell verksamhet (bank, holdingbolag)	64.1xx, 64.2xx, 64.3xx	3
Elektroniska pengar och betalningsinstitut	66.xxx	3
Försäkring och pension	65.xxx	3
MEDEL RISK (2)		
IT-konsulter och programutveckling	62.xxx, 63.xxx	2
Arkitekter, ingenjörer, teknisk konsult	71.xxx	2
Reklam och marknadsföring	73.xxx	2
Advokater och advokatbyråer	69.10.1	2
Valutaväxling och övrig finansiell verksamhet	64.9xx	2
Forskning och utveckling	72.xxx	2
LÅG RISK (1)		
Offentlig förvaltning	84.xxx	1
Utbildning (offentlig)	85.xxx	1
Hälsö- och sjukvård (offentlig)	86.xxx	1
Kommunala bolag	Ägarstruktur	1

Tillämpning: När en ny kund registreras hämtas SNI-kod från Roaring API. Systemet matchar automatiskt mot ovanstående tabell och tilldelar korrekt hotnivå (1–4). Om SNI-koden inte finns i tabellen tilldelas standardvärdet **2 (Medel risk)**.

Översättning av hotnivåer till numerisk skala

För att möjliggöra en enhetlig och kvantitativ tillämpning av riskbedömningen har vi översatt myndigheternas verbala riskkategorier till en numerisk skala enligt följande:

Benämning i myndighetsrapport	Numeriskt värde i vår modell
Låg	1
Medel	2
Betydande	3
Hög	4

Vi tillämpar denna fyrgradiga skala både för hotnivå (extern exponering) och sårbarhetsnivå (intern kontrollförmåga). Den resulterande risknivån erhålls genom multiplikation:

$$\text{Riskvärde}_{\text{PTL}} = \text{Hotnivå} \times \text{Sårbarhetsnivå}$$

Detta ger ett slutligt intervall från 1 till 16 och ligger till grund för våra prioriteringar och åtgärdsplaner enligt penningtvättslagen.

Exempel: En restaurangverksamhet (SNI 56.101) har hotnivå 4 enligt myndighetens klassificering. Våra redovisningstjänster har sårbarhetsnivå 3. Detta ger ett PTL-riskvärde på $4 \times 3 = 12$, vilket klassificeras som *hög risk* och kräver skärpt kundkännedom.

Celestial Risk Engine - Operationell riskbedömning

Syfte och avgränsning

Nytt i v2.0: Förutom den juridiskt förankrade PTL-metoden tillämpar vi en kompletterande *Celestial Risk Engine* för att få en mer detaljerad och operationell riskbild. Denna metod kombinerar:

1. **15 Roaring Risk Indicators** - Offentliga data från Bolagsverket, konkurser, PEP, styrelsebyten etc.
2. **22 Bokföringsflaggor** - Analys av SIE-filer för att upptäcka fraud-mönster
3. **10 Cross-validation rules** - Integritetskontroller mellan Roaring-data och bokföring

Viktigt: Celestial Engine *ersätter inte* PTL-metoden. De två metoderna har olika syften:

PTL-metodik	Celestial Engine
Juridisk grund för KYC-nivå Output: Låg/Normal/Hög risk Beslut: Standard vs Skärpt KYC Baseras på bransch (Hot $\times$ 3)	Operationell prioritering Output: 0–100 poäng Beslut: Accept/Enhanced DD/Reject Baseras på faktisk verksamhet

Beräkningsmodell

Celestial Engine ger varje kund en poäng mellan 0 och 100 enligt följande viktade formel:

$$\text{Score}_{\text{Celestial}} = (S_{\text{Roaring}} \times W_{\text{public}}) + (S_{\text{Bokföring}} \times W_{\text{accounting}}) + (S_{\text{Validation}} \times W_{\text{cross}})$$

där:

- S_{Roaring} = Poäng från Roaring Risk Indicators (0–100)
- $S_{\text{Bokföring}}$ = Poäng från 22 bokföringsflaggor (0–100)
- $S_{\text{Validation}}$ = Poäng från cross-validation (0–100)
- $W_{\text{public}}, W_{\text{accounting}}, W_{\text{cross}}$ = Vikter som summerar till 1.0

Dynamisk viktning baserat på PTL Hot-nivå

Nyckelfunktion: Viktningen anpassas automatiskt baserat på kundens Hot-nivå från PTL-metoden:

Hot	W_{public}	$W_{\text{accounting}}$	W_{cross}	Motivering
4 (Hög)	0.20	0.60	0.20	Bygg/restaurang: offentlig data mindre tillförlitlig, fokus på bokföring
3 (Betydande)	0.25	0.55	0.20	Standard balance
2 (Medel)	0.25	0.55	0.20	Standard balance
1 (Låg)	0.35	0.45	0.20	Offentlig sektor: offentlig data mycket tillförlitlig

Rationalen: I högriskverk samheter (bygg, restaurang) arbetar företag ofta svart, vilket gör offentlig data (Roaring) mindre tillförlitlig. Därför ökar vi vikten på bokföringsanalys till 60%. I offentlig sektor är det tvärtom - offentlig data är mycket tillförlitlig, så vi ökar vikten för Roaring till 35%.

Roaring Risk Indicators (15 regler)

Via Roaring API hämtas följande 15 indikatorer automatiskt:

- fTaxReg** - F-skatterregistrering (false = alarm)
- vatReg** - Momsregistrering (false = alarm om omsättning >80k)
- arbAvgReg** - Arbetsgivaravgift (false = alarm om anställda >0)
- registrationDate** - Nyetablerad (<6 månader = alarm)
- boardChangeCount** - Styrelsebyten (>3/år = instabilitet)
- addressChangeDates** - Adressbyten (>3/år = misstänkt)
- industryCodeChanges** - Branschbyten (>2/år = verksamhetsändring)
- orgDataChanges** - Organisationsdata ändringar (>3/3 år)
- bankruptciesPerReference** - Personliga konkurser (>1 = red flag)
- connectedBankruptcyCompanies** - Nätverk konkurser (>5 = varning)
- pepCount** - PEP-status (>3 = skärpt KYC)
- legalCount** - Rättsliga åtgärder (>3 = dispyter)
- revenueByEmployee** - Omsättning/anställd (<1000 kr = fraud)
- missingAuditor** - Saknar revisor (true = varning om >3M omsättning)
- meanAgeOfRepresentatives** - Medelålder styrelse (35–50 = optimalt)

Varje indikator som triggar alarm ger 5–20 poäng beroende på allvarlighetsgrad. Totalen omvandlas till en skala 0–100.

Bokföringsflaggor (22 regler)

Genom analys av kundens SIE-fil identifieras följande 22 varningsflaggor:

1. Fakturor med jämna belopp ($>30\%$ = round-tripping)
2. Bruten nummerordning (missing invoices = oredovisad försäljning)
3. Kontantinsättningar $>22,000$ SEK (>2000 EUR = obligatorisk skärpt KYC)
4. Oförklarliga utbetalningar ($>50k$ utan faktura)
5. Betalning före förfallodatum utan rabatt (>5 st = samordning)
6. Stora aktieägartillskott ($>500k$ = kontrollera ursprung)
7. Penningflöde till högriskländer
8. Frekventa ägarbyten ($>2/\text{år}$)
9. Privatbostadskostnader i bokföringen
10. Oförklarliga in- och utbetalningar
11. Motpart i högriskland
12. Stora internationella transaktioner utan tydligt syfte
13. Fakturor med varierande utseende (olika format = flera företag?)
14. Snabba ägarbyten vid platsbesök
15. Verksamhet vid platsbesök överensstämmer ej med bokföring
16. Kontinuerligt stora förluster (>3 år = oklar finansiering)
17. Negativt eget kapital (konkursrisk)
18. Likvida medel <1 månads burn rate
19. Överkrediterad (kontokredit $>\text{limit}$)
20. Leverantörsskulder >90 dagar
21. Omsättning/anställd avviker från branschgenomsnitt ($>200\%$)
22. Bruttomarginal $<\text{branschmedian} -50\%$

Varje flagga ger 5–50 poäng beroende på severity (Låg/Medel/Hög/Kritisk).
Totalen omvandlas till 0–100.

Cross-validation (10 regler)

Dessa regler jämför Roaring-data mot bokföringen för att hitta diskrepanser:

1. Omsättning i SIE vs Roaring (>20% skillnad = false reporting)
2. Antal anställda i SIE (via lönekostnad) vs Roaring (>2 skillnad = fake employees)
3. VAT-registrering i Roaring vs moms i SIE (false = fraud)
4. Arbetsgivaravgift i Roaring vs SIE konto 2730 (mismatch = fraud)
5. F-skatt i Roaring vs faktureringsaktivitet i SIE
6. Styrelsebyten i Roaring vs signaturändringar i SIE
7. PEP-status vs högrisk transaktioner i SIE
8. Registreringsdatum i Roaring vs första SIE-post (>6 mån = backdating)
9. Revisor saknas i Roaring men >10M omsättning i SIE (illegal enligt ÅRL)
10. Adressändringar i Roaring vs adressdata i SIE

Varje discrepans ger 10–60 poäng. Totalen omvandlas till 0–100.

Exempel: Restaurang med fraud-mönster

Företag: Mama Mia Pizzeria AB (SNI 56.101)

Steg 1: PTL-metodik (juridisk grund)

- Hot-nivå: 4 (Restaurang = Hög risk enligt myndigheten)
- Sårbarhet: 3 (Redovisningstjänst = Betydande)
- PTL-riskvärde: $4 \times 3 = 12$
- Klassificering: **Hög risk**
- KYC-krav: **Skärpt kundkännedom (3 kap 18 § PTL)**

Steg 2: Celestial Engine (operationell)

Roaring Indicators (2 alarms):

- arbAvgReg = false (10 poäng)
- missingAuditor = true (5 poäng)
- **Roaring Score:** 15/100 (låg public risk)

Bokföringsflaggor (2 kritiska):

- 5 kontantinsättningar >22,000 SEK (50 poäng - KRITISK)
- Bruten fakturaserie #45–#67, 23 st saknas (30 poäng - HÖG)
- **Bokföring Score:** 80/100 (hög fraud risk)

Cross-validation (OK):

- Omsättning: SIE 3.2M vs Roaring 3.0M = 6.7% skillnad (OK)
- **Validation Score:** 0/100 (good consistency)

Viktning (Hot 4):

$$\text{Score}_{\text{Celestial}} = 15 \times 0.20 + 80 \times 0.60 + 0 \times 0.20 = 3 + 48 + 0 = 51$$

Justerat för Hot 4 bransch: $51 + 10 = 61/100$

Steg 3: Beslut

PTL-beslut: Skärpt KYC (Hot 4 bransch)

Celestial-beslut: ACCEPT med Enhanced DD (score 61)

Kombinerat: ACCEPTERA kund MEN:

- OBLIGATORISK skärpt kundkännedom (5 kap 3 § 2 st PTL - kontant >22k)
- Begär förklaring på alla 5 kontantinsättningar
- Begär förklaring på saknade fakturor #45-#67
- Kvartalsvis uppföljning (högriskverksamhet)
- Platsbesök inom 6 månader
- Alla kontanttransaktioner >22k dokumenteras separat

Motivering av sårbarhetsnivåer per tjänst

Vi väljer i denna analys att klassificera samtliga våra tjänster med sårbarhetsnivån **3 – betydande**, i linje med slutsatserna i den myndighetsgemensamma rapporten från 2020/2021. Tjänsterna bygger i stor utsträckning på kundens egna uppgifter och är därmed exponerade för manipulation, även om våra interna rutiner syftar till att motverka detta.

Vi tillämpar denna nivå som en försiktighetsåtgärd och är öppna för revidering vid förändrade förutsättningar eller vägledning från tillsynsmyndighet.

1. Löpande bokföring – Sårbarhet = 3 (betydande)

Enligt den nationella riskbedömningen (kap. 7.15, s. 91) är redovisningsbyråer en särskilt utsatt sektor eftersom de i praktiken kan möjliggöra eller maskera brott genom manipulativ bokföring. Tjänsten bygger på kundens underlag och är ofta beroende av kundens ärlighet. Vi bedömer därför sårbarheten som **betydande**.

Nytt i v2.0: Genom automatisk analys av SIE-filer (22 bokföringsflaggor) minskar vi dock denna sårbarhet i praktiken, eftersom manipulation upptäcks systematiskt.

2. Momsdeklaration – Sårbarhet = 3 (betydande)

Momsfusk utgör enligt rapporten ett vanligt och välkänt modus för ekonomisk brottslighet (s. 40–41). Även om deklarationen i sig är formlig, är underlaget mottagligt för manipulation. Därför klassificeras sårbarheten som **betydande**.

3. Årsbokslut/Årsredovisning – Sårbarhet = 3 (betydande)

Årsbokslut och årsredovisningar är till stor del sammanställningar av redan hanterade transaktioner, men enligt rapporten (s. 85) används de i hög grad för att vilseleda banker och myndigheter. Detta innebär en betydande sårbarhet eftersom manipulation ofta sker genom selektiv presentation av data.

4. Inkomstdeklaration – Sårbarhet = 3 (betydande)

Trots att deklarationen skickas till Skatteverket sker själva datainsamlingen internt eller via konsult. Deklarationen är därför beroende av kundens rapportering och dokumentation, vilket öppnar för otillbörlig påverkan. Riskbedömningen stöder att sårbarheten för denna typ av tjänst bedöms som **betydande**.

Sammanfattande beslutsmodell

Vår tvådelade riskbedömning resulterar i följande beslutsmatris:

PTL-risk	Celestial	Beslut	Åtgärder
Låg (1-3)	0-30	Accept	Standard KYC, årlig uppföljning
Låg (1-3)	31-60	Accept	Standard KYC, halvårsvis uppföljning
Låg (1-3)	61-80	Enhanced DD	Fördjupad granskning innan accept
Låg (1-3)	81-100	Reject	Fraud bevis trots låg PTL-risk
Normal (4-6)	0-30	Accept	Standard KYC, halvårsvis uppföljning
Normal (4-6)	31-60	Accept	Standard KYC, kvartalsvis uppföljning
Normal (4-6)	61-80	Enhanced DD	Fördjupad kontroll + extra dokumentation
Normal (4-6)	81-100	Reject	Fraud upptäckt
Hög (7+)	0-30	Accept	Skärpt KYC, kvartalsvis uppföljning
Hög (7+)	31-60	Accept	Skärpt KYC, månatlig uppföljning
Hög (7+)	61-80	Enhanced DD	Skärpt KYC + VD-godkännande
Hög (7+)	81-100	Reject	Kombinerad hög risk + fraud

Särskilda krav vid kontanthantering

Enligt 5 kap 3 § 2 st penningtvättslagen är skärpt kundkännedom **obligatorisk** vid:

- Enstaka transaktion motsvarande minst 2000 euro (ca 22,000 SEK) i kontanter
- Flera sammanhängande transaktioner som tillsammans uppgår till minst 2000 euro

Celestial Engine flaggar automatiskt alla kontantinsättningar >22,000 SEK i SIE-filen och kräver skärpt KYC oavsett övrig riskprofil.

Dokumentation och spårbarhet

Varje riskbedömning ska dokumenteras och arkiveras enligt följande:

1. PTL-riskbedömning (juridisk dokumentation)

- Hot-nivå (1–4) med källhänvisning till myndighetsrapport
- Sårbarhetsnivå (konstant 3 för redovisningstjänster)
- Riskvärde ($\text{Hot} \times 3$)
- Klassificering: Låg/Normal/Hög risk
- KYC-nivå: Standard eller Skärpt
- Eventuella justeringar (PEP +4, högriskland +3, nyetablerad +2 etc.)
- Beslutsdatum och ansvarig

2. Celestial Engine rapport (operationell dokumentation)

- Roaring Score (0–100) med lista på triggade indikatorer
- Bokföring Score (0–100) med lista på flaggor
- Validation Score (0–100) med lista på discrepanser
- Total Celestial Score efter viktning
- Top 5 riskfaktorer
- Beslut: Accept/Enhanced DD/Reject
- Alla Roaring API-svar arkiverade (JSON)
- SIE-fil analyserad (arkiverad separat)

3. Kombinerat beslutsdokument

Ett sammanfattande dokument som inkluderar:

- Båda riskbedömningarna (PTL + Celestial)
- Slutligt beslut med motivering
- Specificerade åtgärder och uppföljningsplan
- Signatur från verksamhetsansvarig

Dokumentationen ska bevaras i minst 5 år från det att affärsförbindelsen upphört (4 kap 8 § penningtvättslagen).

Uppdatering och revidering

Denna metodbeskrivning ska ses över och vid behov uppdateras:

- Minst en gång per år
- Vid ändrad lagstiftning eller nya föreskrifter
- Vid ny vägledning från Länsstyrelsen eller annan tillsynsmyndighet
- Vid väsentliga förändringar i den nationella riskbedömningen
- Vid identifierade brister i den egna verksamheten
- Vid uppdatering av Roaring API eller Celestial Engine

Version 2.0 (2025-10-24): Integration av Celestial Risk Engine med automatiserad datainsamling via Roaring API och bokföringsanalys. Separation mellan PTL-metodik (juridisk) och operationell riskbedömning (Celestial). Dynamisk viktning baserat på Hot-nivå. Uppdatering till SNI 2025.

Tidigare versioner:

- Version 1.0: Grundläggande PTL-metodik (Hot × Sårbarhet)

Godkänd av: _____

Datum: _____

Nästa revidering: _____